

Information security strategy for hospital and healthcare system

Hassan khaled Musllam Aldajah	0222600
Mohammed Mmamon	2211969
Saif Thamer AL-Goman	0217215

Supervisor: Dr. Thamer alajrami
may / 2025



Abstract

This paper talks about a very important topic in hospitals — Information Security. Hospitals work with sensitive data like patient information, so they really need good systems to protect this data from hackers and other threats.

The paper explains how a hospital can plan and set up a good security system. It talks about the goals of the plan, how to know if it's working, and what risks there might be. It also gives a list of steps the hospital can follow to make things better, and some tips for the future.

Organizational Context and Assumptions

About the Hospital

MedCare Hospital is a made-up (fictional) hospital. It's medium-sized and has about 350 beds. It offers many services like emergency care, lab tests, clinics, and scans.

The hospital uses different kinds of technology, like:

- Electronic Health Records (EHR): These keep all the patient's information in digital form.
- Hospital Management System (HMS): Helps manage appointments, billing, and admin work.
- Telehealth platforms: Let patients talk to doctors online without visiting the hospital.
- Connected medical devices (IoT): Machines like ventilators or infusion pumps that are connected to the hospital's computer system.

Important Things That Need Protection

1. EHR systems: Store all the patient's health records.
2. Imaging storage: Keeps medical images like X-rays and MRIs.
3. Lab databases: Store test results that are linked to the patient.
4. ID systems: Manage logins and access for both staff and patients.
5. Hospital network: Connects all systems to each other.
6. Medical equipment: Devices connected to the network that could be attacked if not protected.

Rules and Laws the Hospital Follows :

1. Jordanian Health Regulations: Local laws in Jordan that tell hospitals how to handle patient data.
2. GDPR: A European law that protects the data of international patients.
3. HIPAA: A U.S. law that makes sure health info is kept private and safe, especially for insurance.

Current Security Situation

Right now, the hospital has only basic protection:

- It uses antivirus software and firewalls.

But it doesn't have important things, like:

- Special access levels (so only the right people can see certain data).
- Encrypted databases (so data isn't easy to steal).
- A clear plan for what to do during a cyberattack.
- A system to watch everything in one place.
- Protected medical devices (they're connected directly, which is risky).

Why Security Is Important

1. Moving to digital systems: Hospitals are using more tech and less paper, so data must be protected.
2. Telemedicine is growing: More people are getting care online, which brings more risks.
3. Laws and audits: Hospitals need to follow the rules or they can get in trouble.
4. Cyberattacks are increasing: Hackers are targeting hospitals more and more with phishing and ransomware.

People Involved in Security (Stakeholders)

1. Board of Directors: Make big decisions and approve budgets.
2. Chief Information Officer (CIO): Manages the hospital's technology systems.
3. Chief Information Security Officer (CISO): Focuses on keeping the systems safe.
4. IT Department: Does the technical work like setting up security, updates, and access.
5. Doctors and Nurses: Use patient systems every day — they can affect security too.
6. HR Department: Makes sure each employee has the right level of access.
7. Auditors and Regulators: Check that the hospital is following the laws.

8. Third-party vendors: Companies that provide tech tools and must follow the hospital's security rules.

(2) Five Strategic Information Security Goals (1–3 Year Horizon)

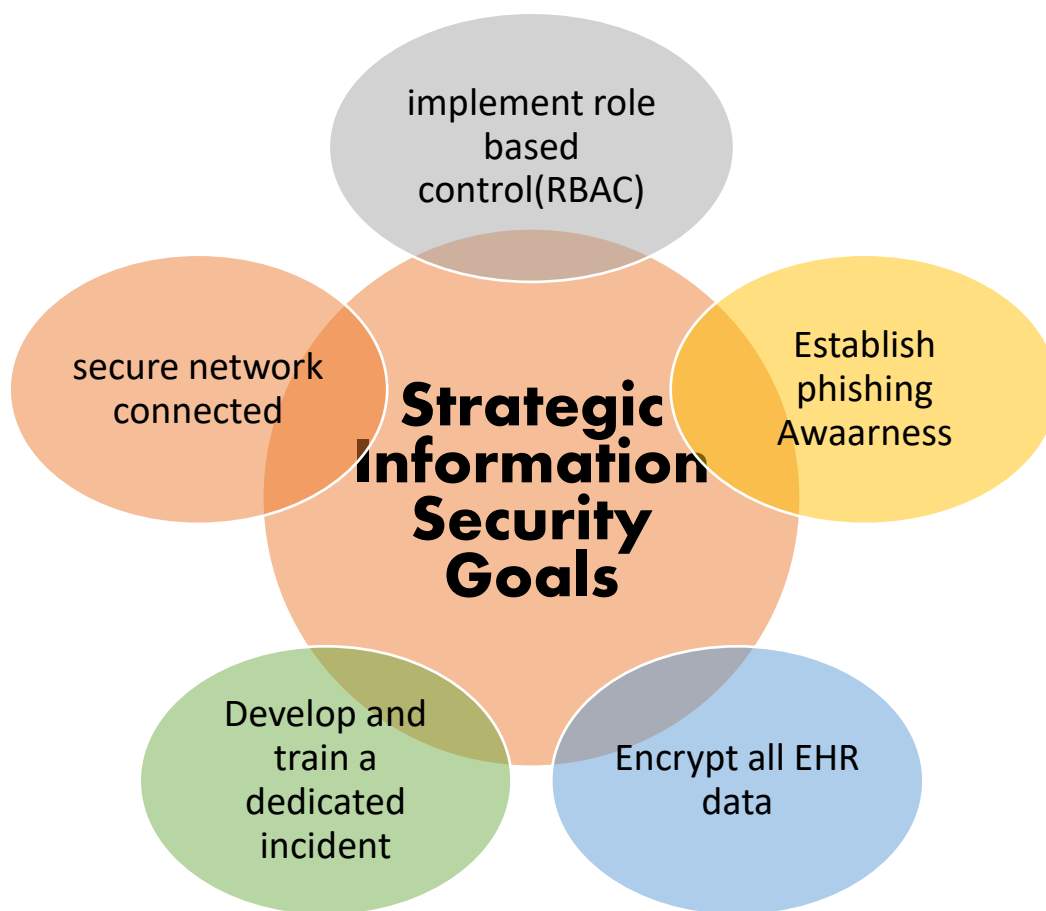


Figure 1Strategic Information Security Goals

Goal 1: Use Role-Based Access Control (RBAC) :

Only let people access what they need for their job.

How to know it's working ?

Every staff member is assigned access based on their role.

Less cases of data misuse happen.

1) What to do:

Set up an Identity and Access Management (IAM) system.

Hold workshops to explain job roles.

Regularly review access permissions.

2) How to measure success:

100% of staff assigned by Q3 2026.

Zero major violations in monthly audits.

Why it matters ?

Reduces insider risks by limiting access to only what's needed.

Goal 2: Raise Staff Awareness About Phishing Attacks

Reduce the number of people falling for phishing emails.

1) How to know it's working:

Fewer people fail phishing tests.

More suspicious emails are reported.

2) What to do:

Provide training every 3 months.

Run phishing simulations monthly.

Give feedback sessions after tests.

3) How to measure success:

Less than 5% fail rate by the second year.

100% staff complete certification.

4) Why it matters:

Cuts down on social engineering attacks.

Goal 3: Protect Network-Connected Medical Devices

Stop cyber threats coming through medical devices.

1) How to know it's working:

Know exactly what devices are connected.

Set up secure network zones for these devices.

2) What to do:

Audit all IoT devices.

Segment the network.

Keep devices up-to-date with patches.

3) How to measure success:

90% of devices isolated in secure zones by 2027.

100% of supported devices patched.

4) Why it matters:

Stops hackers from moving across the network if one device is hacked.

Goal 4: Build and Train a Dedicated Incident Response Team

Be ready to react fast when cyber incidents happen.

1) How to know it's working:

Have a clear incident response plan.

Team runs regular practice drills.

2) What to do:

Create detailed response playbooks.

Assign clear roles in the team.

Conduct drills regularly.

3) How to measure success:

Detect and contain incidents in less than 2 hours.

Team scores 90% or higher in drills twice a year.

4) Why it matters:

Reduces recovery time and limits damage from attacks.

5) Goal 5: Encrypt All Electronic Health Record (EHR) Data

Keep patient data private and safe from attacker

1. How to know it's working:

All data is encrypted when stored and when sent.

2. What to do ?

Use strong encryption like AES-256.

Secure APIs that share data.

Train staff on handling data securely.

3. How to measure success:

100% encrypted by Q4 2027.

No leaks of unencrypted records.

4. Why it matters:

Protects patient data even if systems are hacked.

3.Action plan :

To make the five strategic goals happen, MedCare Hospital created a clear action plan. This plan explains what steps need to be done for each goal, who is responsible, when it should be done, what other tasks it depends on, and what resources are needed. This way, every action can be tracked and fits well with what the hospital can handle.

Initiative	Description	Timeline	Owners	Dependencies	Budget	Resources
IAM System Implementation (Supports Goal 1)	Deploy a centralized Identity and Access Management (IAM) platform to enable role-based access controls across hospital systems.	Q1–Q3 2026	CIO + IT Dept.	Job-role definitions from HR, budget approval, vendor selection	\$70,000	IAM software, technical integration, staff training
Phishing Awareness Program (Supports Goal 2)	Launch a comprehensive training program integrated with a Learning Management System (LMS), alongside simulated phishing campaigns.	Q2 2026 onward (ongoing)	CISO + HR	Training content, phishing simulation vendor	\$12,000/year	LMS platform, simulation tool, communications team
IoT Network Segmentation (Supports Goal 3)	Isolate critical medical IoT devices into segmented networks and apply a strict patching policy.	Q3 2026–Q2 2027	IT Director	Network mapping, biomedical team cooperation	\$30,000	Switches, VLAN configuration, asset tracking
Incident Response Team Formation (Supports Goal 4)	Create a cross-functional team and develop playbooks for breach response	Q2–Q4 2026	Security Officer	Executive endorsement, legal review, clinical coordination	Internal	Staff training, tabletop simulations, policy templates
EHR Data Encryption (Supports Goal 5)	Enable full-disk encryption on servers and devices handling EHRs, and secure API communication.	2026–2027	CTO + IT Security	Compatibility with legacy systems	\$85,000	Encryption software, endpoint configuration

(4) Strategic Roadmap :

MedCare Hospital's plan is organized into three time phases: short-term (0–6 months), mid-term (6–18 months), and long-term (18–36 months). This way, the hospital can manage budgets, training, and changes more smoothly.

Short-Term (0–6 months)

- Create a plan to communicate with everyone involved
- Start looking for IAM system vendors (request for proposals)
- Begin phishing training with a small test group
- Build the incident response plan and assign team roles
- Take inventory of the network and medical IoT devices

Mid-Term (6–18 months)

- Fully set up IAM system with access monitoring
- Start monthly phishing tests for all staff
- Separate the network and add security for medical devices
- Run the first incident response practice drill
- Buy encryption tools for patient record systems

Long-Term (18–36 months)

- Finish encrypting all patient records across the hospital
- Do a full audit using international security standards (ISO/IEC 27001)
- Add behavior analytics tools to detect unusual activity inside the system
- Update training, policies, and access controls every year

Why this ?

The roadmap focuses first on actions that quickly reduce risks and meet legal rules. IAM and phishing efforts stop common attacks fast. Encryption and network separation need more resources and training, so they come later to give time for preparation.

(5) Gap Assessment (Using ISO/IEC 27001:2022)

The gap analysis assesses the hospital's existing controls against the requirements outlined in ISO/IEC 27001 Annex A. Each control is rated as Compliant, Partially Compliant, or Non-Compliant.

Control Domain	Status	Comments
A.5: Information Security Policy	Compliant	Updated annually, approved by executive leadership
A.9: Access Control	Partially Compliant	IAM system pending; access rights not monitored
A.10: Cryptography	Non-Compliant	No encryption for stored or transmitted EHR data
A.13: Communications Security	Partially Compliant	No VPNs: email filtering is basic
A.16: Incident Response	Non-Compliant	No documented response plan or trained response team

Improvement Recommendations:

- Immediately launch IAM implementation to address A.9
- Introduce AES-256 encryption for A.10 compliance
- Formalize incident response policy under A.16
- Deploy VPN for external communications under A.13
- Retain simplified ISO alignment to reduce cost and complexity

(6) Executive Summary and Recommendations

MedCare Horizon Hospital's information security plan tackles the biggest cybersecurity risks while also matching the hospital's business goals and legal requirements. Over the next three years, the hospital will focus on five main areas by using technical tools, clear processes, and training for people:

1. Control access based on job roles using an Identity and Access Management (IAM) system
2. Keep staff aware of phishing attacks through ongoing training
3. Protect medical IoT devices by separating networks and keeping devices updated
4. Prepare a ready incident response team with clear instructions
5. Encrypt patient data both when stored and when sent

What the hospital will gain ?

- Lower chances of data breaches and insider threats
- More trust from patients, insurance companies, and regulators
- Compliance with important laws like GDPR and HIPAA
- Better readiness for audits and reviews

What is needed from hospital leaders ?

- Approve a budget of about \$200,000
- Support making training programs mandatory for staff
- Monitor progress by reviewing key indicators every three months

This plan is a hospital-wide effort to improve security in a realistic and manageable way, making the hospital stronger and safer in its digital systems.

References:

1. Wager, K. A., Lee, F. W., & Glaser, J. P. (2021). Healthcare Information Systems: A Practical Approach for Health Care Management (4th ed.). Jossey-Bass.
2. ISACA. (2019). COBIT 2019 Framework: Introduction and Methodology. ISACA Publications.
3. The course textbook was also used as a reference to support the strategy

